

The Spring IAM slice

Trace sign-in, tokens, authorization, and tests through the code Aegis actually has.

BOUNDARY

A real sign-in slice – no signup yet

The Web and iOS apps authenticate through the Spring API; the database is private.

Implemented

POST /api/v1/auth/login
GET /api/v1/auth/me
JWT validation and live account
lookup

Not implemented

No public registration route
No refresh token
No Web/iOS auth client yet

Authority

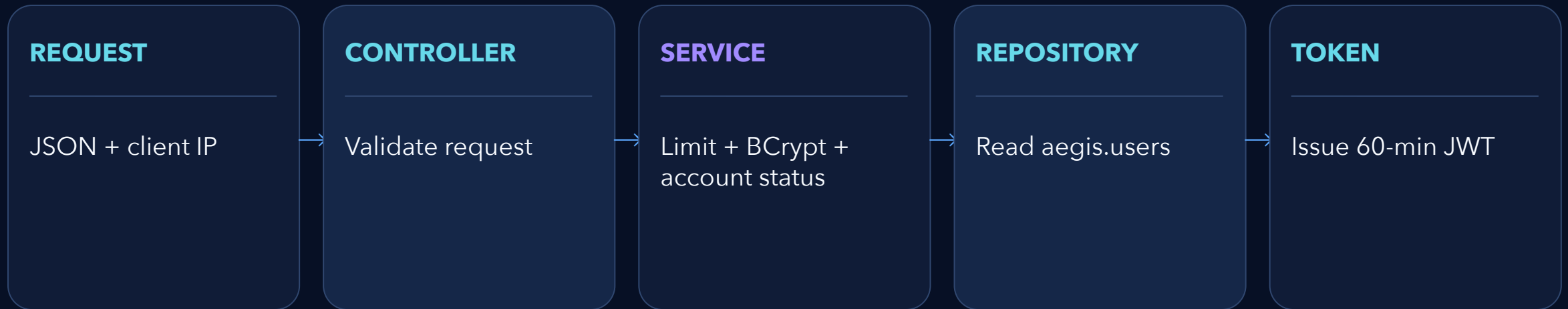
Only Spring grants access.
Neither a UI form nor an ESP32
can create a session or role.

A registration screen is a product and trust decision, not a front-end-only feature.

REQUEST PATH

What POST /auth/login does

The public route permits a request, but the service still verifies the credentials.



Invalid credentials return one refusal path; no account existence is disclosed.

BUSINESS LOGIC

The controller is thin; the service decides

Trace the actual login service instead of placing credential logic in HTTP code.

AUTHENTICATIONSERVICE.JAVA · CONDENSED

```
attempts.acquire(clientAddress, request.email());
var candidate = accounts.findByEmail(request.email());
boolean matches = passwordEncoder.matches(
    request.password(),
    candidate.map(Account::passwordHash)
               .orElse(unknownAccountHash));
var account = candidate
    .filter(a -> matches && a.canAuthenticate())
    .orElseThrow(InvalidCredentialsException::new);
```

Why a dummy hash?

An unknown address still goes through a password-hash check.

Why check status?

A disabled account cannot authenticate even with a correct password.

PROTECTED REQUEST

GET /auth/me does not trust stale roles

The token establishes identity; the current database account remains the authorization source.

1 Verify JWT

Check HS256 signature, issuer, audience, subject, ID, issue time, and expiry.

2 Re-read account

Load the account by token subject; reject it if disabled or missing.

3 Apply current role

Build authentication from the database's current role and access level.

A role claim records login-time state. It is not the final grant on later requests.

SECURITY DEFAULTS

Stateless means explicit bearer tokens

Aegis disables browser-session flows and controls every documented route.

SECURITYCONFIGURATION.JAVA · EXCERPT

```
.csrf(AbstractHttpConfigurer::disable)
.sessionManagement(s -> s.sessionCreationPolicy(
    SessionCreationPolicy.STATELESS))
.httpBasic(AbstractHttpConfigurer::disable)
.formLogin(AbstractHttpConfigurer::disable)
```

Public routes

A stale bearer header is ignored on login and health routes.

Protected routes

Require a valid token and a live, authorized account.

There is no refresh token in the current P0 IAM design.

EVIDENCE

Test behavior, not just compilation

The integration suite uses MockMvc and isolated real PostgreSQL.

Login

Correct credentials work; wrong and unknown users get indistinguishable refusal; expired tokens fail.

Authorization

A role or account-status change in the database affects already-issued tokens.

Schema

Flyway starts a fresh database and validates migration ordering.

Read the test that proves each claim before you change that behavior.

PRACTICE

Your IAM code tour

Follow one login and one /me request. Then answer these questions without looking.

- | | | |
|----|---|---|
| 01 | <code>AuthController.java</code> | What does the controller delegate? |
| 02 | <code>AuthenticationService.java</code> | Where are credentials and status checked? |
| 03 | <code>AccessTokens.java</code> | What expires, and when? |
| 04 | <code>CurrentAccountAuthenticationConverter.java</code> | Why re-read the account? |

Next decision: define who may create accounts before adding signup to the API.